

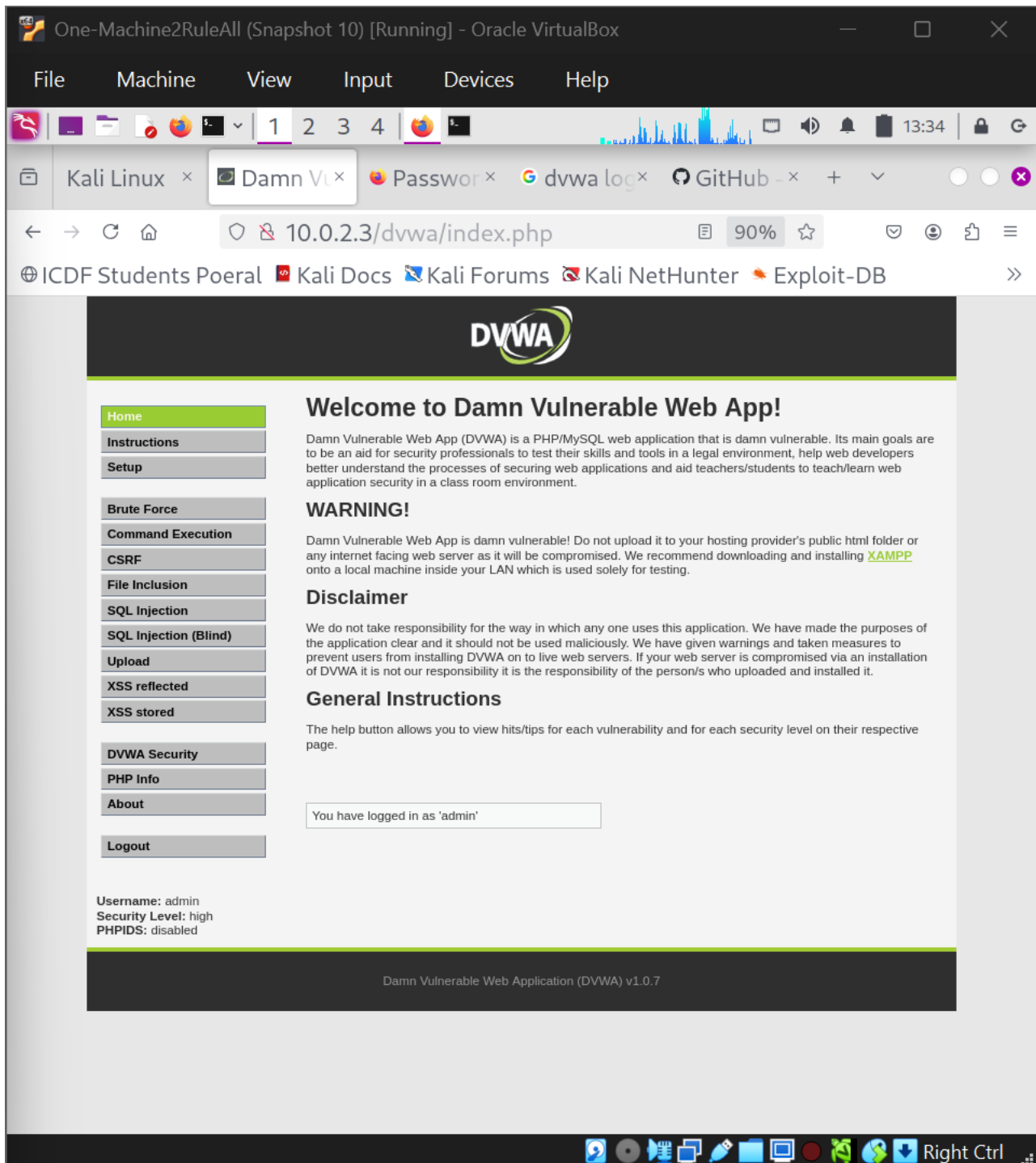
Full name: Adeleke Oluwapelumi Faruq

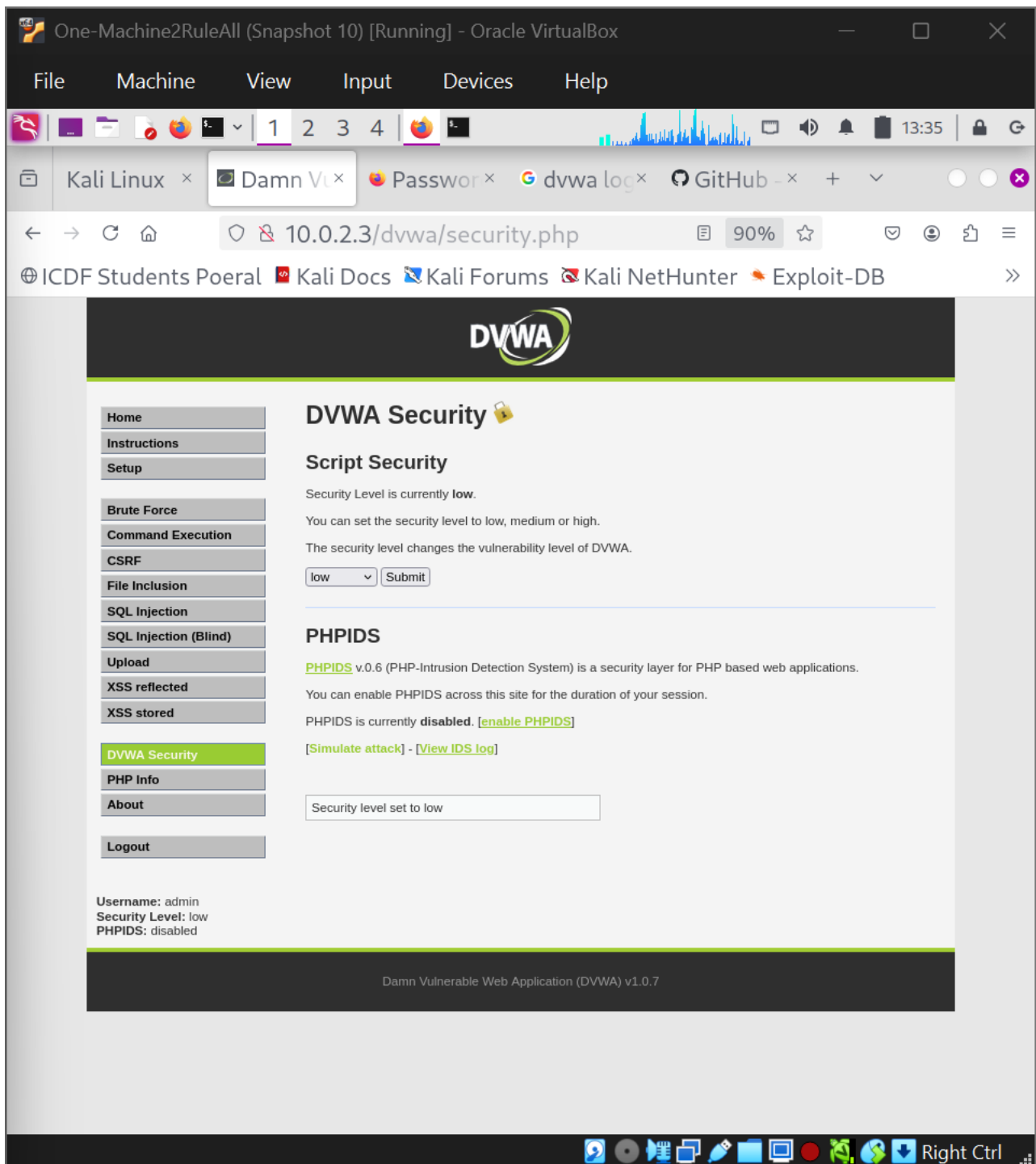
Registration number: C11/26/FCDF/17167

Linux distribution / version: Kali GNU/ 2025.1

VM hostname: Oracle VirtualBox

Part 2





Part3

One-Machine2RuleAll (Snapshot 10) [Running] - Oracle VirtualBox

File Machine View Input Devices Help

Kali Linux x Damn Vu x Passwor x dvwa log x GitHub - x + v 13:38

10.0.2.3/dvwa/security.php 90% ☆

ICDF Students Poeral Kali Docs Kali Forums Kali NetHunter Exploit-DB >>

DVWA Security

Script Security

Security Level is currently **low**.

You can set the security level to low, medium or high.

The security level changes the vulnerability level of DVWA.

low Submit

PHPIDS

PHPIDS v.0.6 (PHP-Intrusion Detection System) is a security layer for PHP based web applications.

You can enable PHPIDS across this site for the duration of your session.

PHPIDS is currently **disabled**. [\[enable PHPIDS\]](#)

[\[Simulate attack\]](#) - [\[View IDS log\]](#)

Navigation Menu:

- Home
- Instructions
- Setup
- Brute Force
- Command Execution
- CSRF
- File Inclusion
- SQL Injection
- SQL Injection (Blind)
- Upload
- XSS reflected
- XSS stored
- DVWA Security**
- PHP Info
- About
- Logout

Inspector Console Debugger Network Style Editor Performance Memory Storage Accessibility >> ... X

Filter URLs

Filter Headers

S...	Met	Domain	File	Initiator	Typ	Transf...	Size
200	GET	10.0.2.3	security.php	docu...	htm	4.46 kB	4.10
200	GET	10.0.2.3	dvwaPage.js	script	js	cached	7...
200	GET	10.0.2.3	logo.png	img	png	cached	8.30
200	GET	10.0.2.3	lock.png	img	png	cached	1...
200	GET	10.0.2.3	favicon.ico	Favico...	x...	cached	1...

5 requests | 15.98 kB / 4.46 kB transferred | Finish: 967 ms | DOMC

GET http://10.0.2.3/dvwa/security.php

Status: **200 OK**

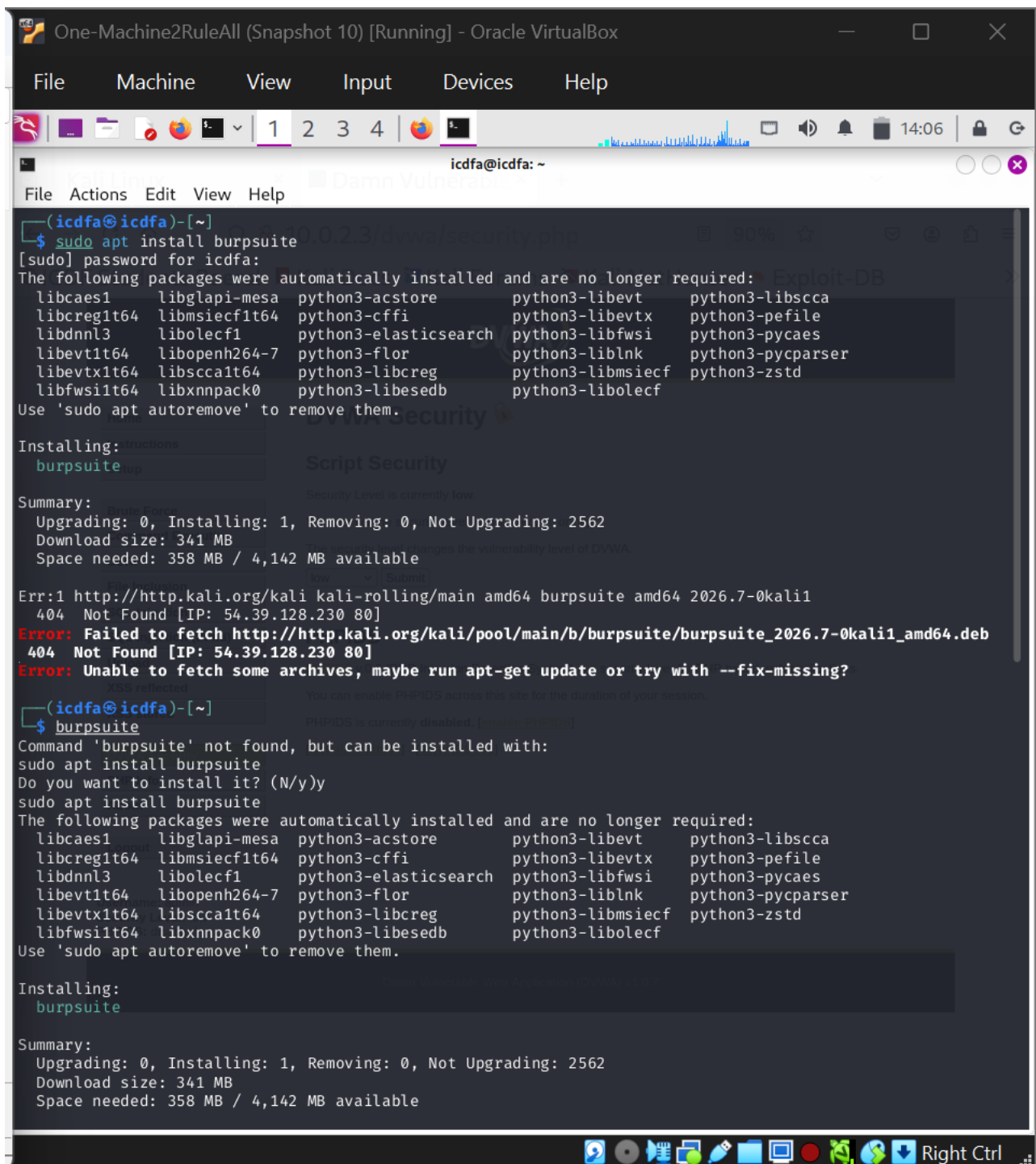
Version: HTTP/1.1

Transferred: 4.46 kB (4.10 kB size)

Referrer Policy: strict-origin-when-cross-origin

Right Ctrl

Part4



```
(icdfa@icdfa)-[~]
$ sudo apt install burpsuite
[sudo] password for icdfa:
The following packages were automatically installed and are no longer required:
libcaes1 libglapi-mesa python3-acstore python3-libevt python3-libscca
libcreg1t64 libmsiecf1t64 python3-cffi python3-libevtx python3-pefile
libdnnl3 libolecf1 python3-elasticsearch python3-libfws python3-pycaes
libevt1t64 libopenh264-7 python3-flor python3-liblnk python3-pycparser
libevtx1t64 libscca1t64 python3-libreg python3-libmsiecf python3-zstd
libfws1t64 libxnnpack0 python3-libesedb python3-libolecf
Use 'sudo apt autoremove' to remove them.

Installing:
burpsuite

Summary:
Upgrading: 0, Installing: 1, Removing: 0, Not Upgrading: 2562
Download size: 341 MB
Space needed: 358 MB / 4,142 MB available

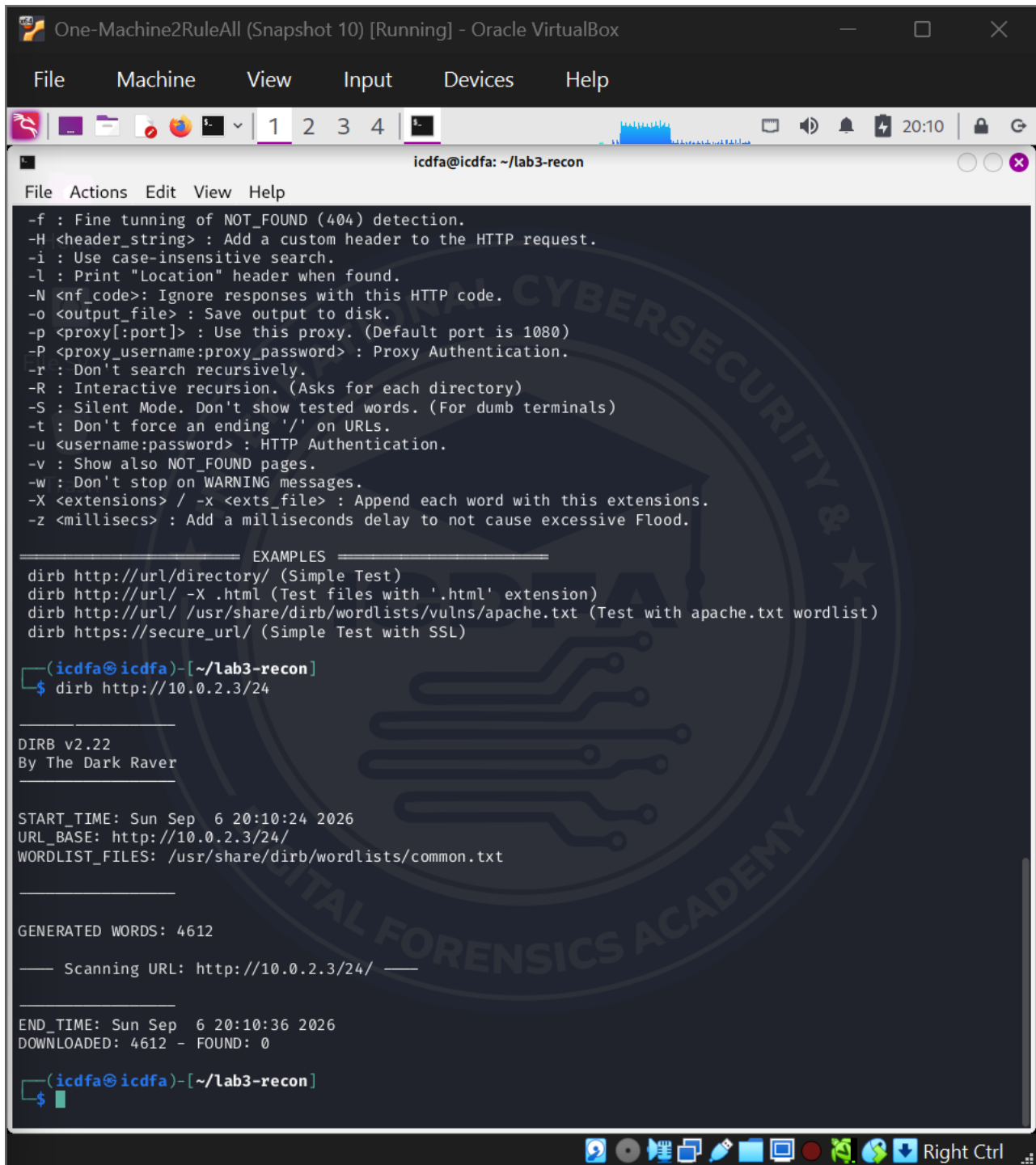
Err:1 http://http.kali.org/kali kali-rolling/main amd64 burpsuite amd64 2026.7-0kali1
404 Not Found [IP: 54.39.128.230 80]
Error: Failed to fetch http://http.kali.org/kali/pool/main/b/burpsuite/burpsuite_2026.7-0kali1_amd64.deb
404 Not Found [IP: 54.39.128.230 80]
Error: Unable to fetch some archives, maybe run apt-get update or try with --fix-missing?

(icdfa@icdfa)-[~]
$ burpsuite
Command 'burpsuite' not found, but can be installed with:
sudo apt install burpsuite
Do you want to install it? (N/y)y
sudo apt install burpsuite
The following packages were automatically installed and are no longer required:
libcaes1 libglapi-mesa python3-acstore python3-libevt python3-libscca
libcreg1t64 libmsiecf1t64 python3-cffi python3-libevtx python3-pefile
libdnnl3 libolecf1 python3-elasticsearch python3-libfws python3-pycaes
libevt1t64 libopenh264-7 python3-flor python3-liblnk python3-pycparser
libevtx1t64 libscca1t64 python3-libreg python3-libmsiecf python3-zstd
libfws1t64 libxnnpack0 python3-libesedb python3-libolecf
Use 'sudo apt autoremove' to remove them.

Installing:
burpsuite

Summary:
Upgrading: 0, Installing: 1, Removing: 0, Not Upgrading: 2562
Download size: 341 MB
Space needed: 358 MB / 4,142 MB available
```

Part 7



```
One-Machine2RuleAll (Snapshot 10) [Running] - Oracle VirtualBox
File Machine View Input Devices Help
1 2 3 4
icdfa@icdfa: ~/lab3-recon
File Actions Edit View Help
-f : Fine tuning of NOT_FOUND (404) detection.
-H <header_string> : Add a custom header to the HTTP request.
-i : Use case-insensitive search.
-l : Print "Location" header when found.
-N <nf_code>: Ignore responses with this HTTP code.
-o <output_file> : Save output to disk.
-p <proxy[:port]> : Use this proxy. (Default port is 1080)
-P <proxy_username:proxy_password> : Proxy Authentication.
-r : Don't search recursively.
-R : Interactive recursion. (Asks for each directory)
-S : Silent Mode. Don't show tested words. (For dumb terminals)
-t : Don't force an ending '/' on URLs.
-u <username:password> : HTTP Authentication.
-v : Show also NOT_FOUND pages.
-w : Don't stop on WARNING messages.
-X <extensions> / -x <exts_file> : Append each word with this extensions.
-z <millisecs> : Add a milliseconds delay to not cause excessive Flood.

===== EXAMPLES =====
dirb http://url/directory/ (Simple Test)
dirb http://url/ -X .html (Test files with '.html' extension)
dirb http://url/ /usr/share/dirb/wordlists/vulns/apache.txt (Test with apache.txt wordlist)
dirb https://secure_url/ (Simple Test with SSL)

(icdfa@icdfa)-[~/lab3-recon]
$ dirb http://10.0.2.3/24

-----
DIRB v2.22
By The Dark Raver

-----
START_TIME: Sun Sep  6 20:10:24 2026
URL_BASE: http://10.0.2.3/24/
WORDLIST_FILES: /usr/share/dirb/wordlists/common.txt

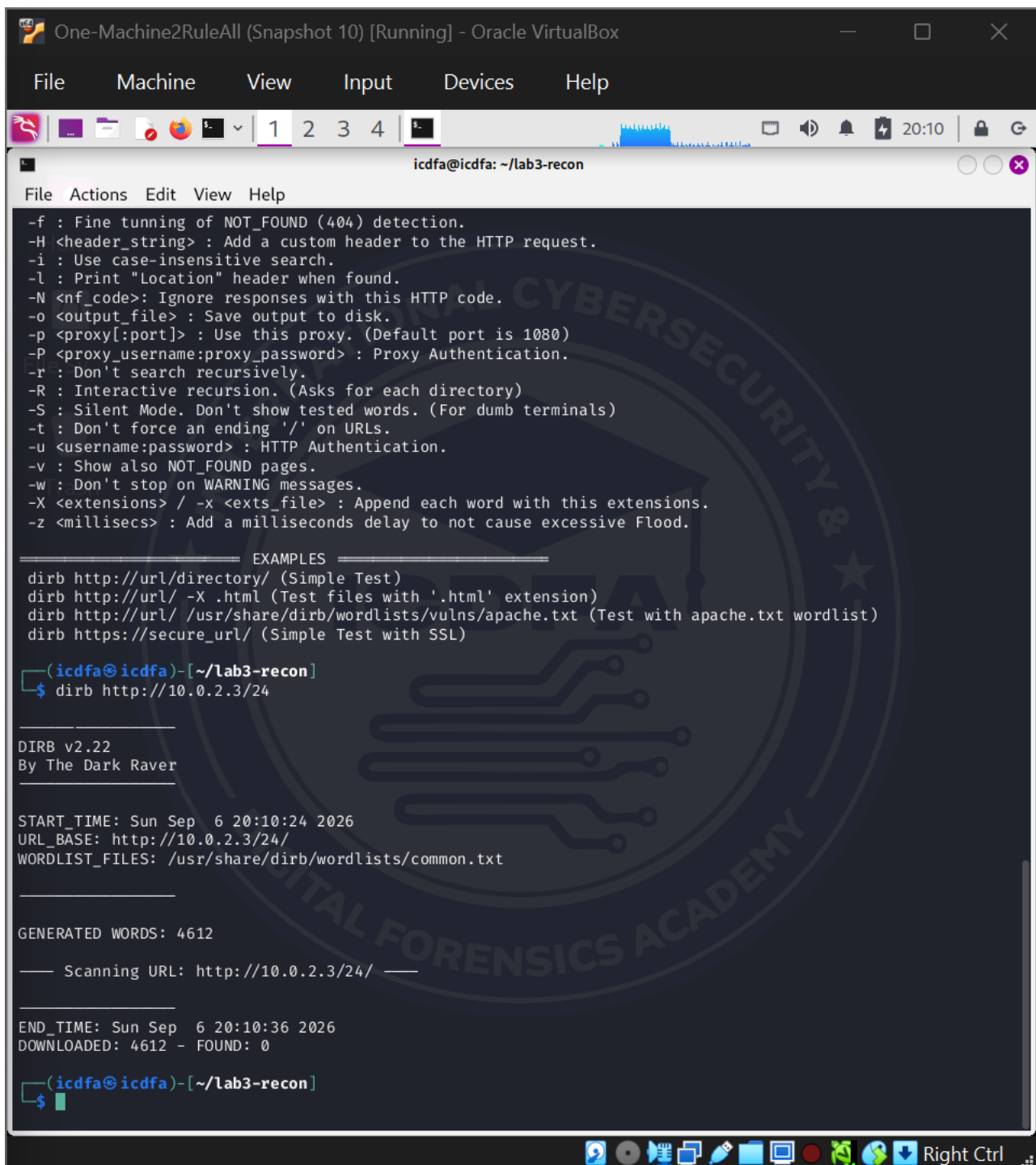
-----
GENERATED WORDS: 4612

----- Scanning URL: http://10.0.2.3/24/ -----

END_TIME: Sun Sep  6 20:10:36 2026
DOWNLOADED: 4612 - FOUND: 0

(icdfa@icdfa)-[~/lab3-recon]
$
```

Part 8



```
One-Machine2RuleAll (Snapshot 10) [Running] - Oracle VirtualBox
File Machine View Input Devices Help

icdfa@icdfa: ~/lab3-recon
File Actions Edit View Help

-f : Fine tuning of NOT_FOUND (404) detection.
-H <header_string> : Add a custom header to the HTTP request.
-i : Use case-insensitive search.
-l : Print "Location" header when found.
-N <nf_code>: Ignore responses with this HTTP code.
-o <output_file> : Save output to disk.
-p <proxy[:port]> : Use this proxy. (Default port is 1080)
-P <proxy_username:proxy_password> : Proxy Authentication.
-r : Don't search recursively.
-R : Interactive recursion. (Asks for each directory)
-S : Silent Mode. Don't show tested words. (For dumb terminals)
-t : Don't force an ending '/' on URLs.
-u <username:password> : HTTP Authentication.
-v : Show also NOT_FOUND pages.
-w : Don't stop on WARNING messages.
-X <extensions> / -x <exts_file> : Append each word with this extensions.
-z <millisecs> : Add a milliseconds delay to not cause excessive Flood.

===== EXAMPLES =====
dirb http://url/directory/ (Simple Test)
dirb http://url/ -X .html (Test files with '.html' extension)
dirb http://url/ /usr/share/dirb/wordlists/vulns/apache.txt (Test with apache.txt wordlist)
dirb https://secure_url/ (Simple Test with SSL)

(icdfa@icdfa)-[~/lab3-recon]
$ dirb http://10.0.2.3/24

-----
DIRB v2.22
By The Dark Raver

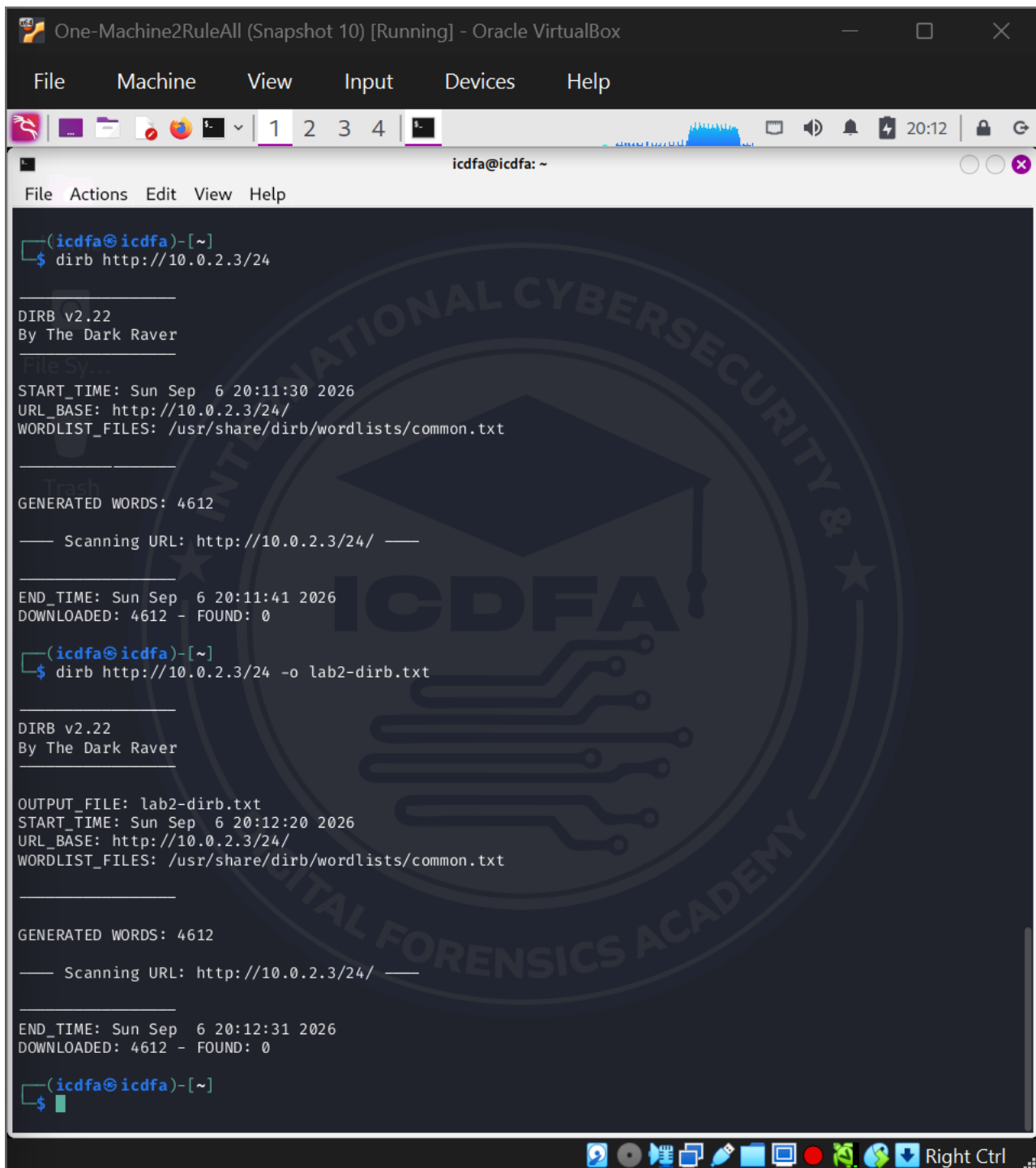
-----
START_TIME: Sun Sep  6 20:10:24 2026
URL_BASE: http://10.0.2.3/24/
WORDLIST_FILES: /usr/share/dirb/wordlists/common.txt

-----
GENERATED WORDS: 4612

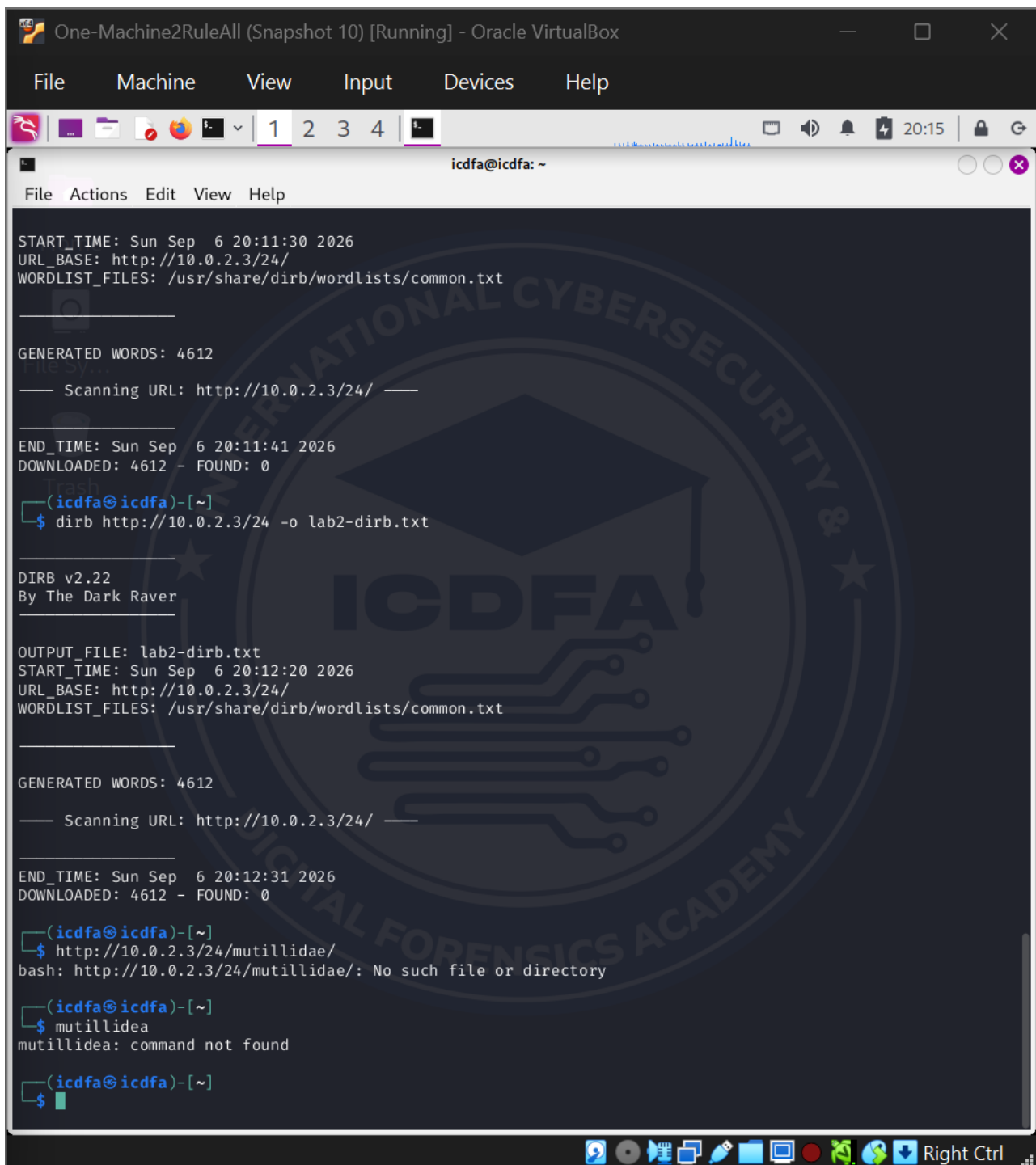
----- Scanning URL: http://10.0.2.3/24/ -----

END_TIME: Sun Sep  6 20:10:36 2026
DOWNLOADED: 4612 - FOUND: 0

(icdfa@icdfa)-[~/lab3-recon]
$
```



Part 9



```
One-Machine2RuleAll (Snapshot 10) [Running] - Oracle VirtualBox
File Machine View Input Devices Help

1 2 3 4 5-

icdfa@icdfa: ~
File Actions Edit View Help

START_TIME: Sun Sep  6 20:11:30 2026
URL_BASE: http://10.0.2.3/24/
WORDLIST_FILES: /usr/share/dirb/wordlists/common.txt

GENERATED WORDS: 4612
— Scanning URL: http://10.0.2.3/24/ —

END_TIME: Sun Sep  6 20:11:41 2026
DOWNLOADED: 4612 - FOUND: 0

(icdfa@icdfa)-[~]
$ dirb http://10.0.2.3/24 -o lab2-dirb.txt

DIRB v2.22
By The Dark Raver

OUTPUT_FILE: lab2-dirb.txt
START_TIME: Sun Sep  6 20:12:20 2026
URL_BASE: http://10.0.2.3/24/
WORDLIST_FILES: /usr/share/dirb/wordlists/common.txt

GENERATED WORDS: 4612
— Scanning URL: http://10.0.2.3/24/ —

END_TIME: Sun Sep  6 20:12:31 2026
DOWNLOADED: 4612 - FOUND: 0

(icdfa@icdfa)-[~]
$ http://10.0.2.3/24/mutillidae/
bash: http://10.0.2.3/24/mutillidae/: No such file or directory

(icdfa@icdfa)-[~]
$ mutillidea
mutillidea: command not found

(icdfa@icdfa)-[~]
$
```

Part 11



```
One-Machine2RuleAll (Snapshot 10) [Running] - Oracle VirtualBox
File Machine View Input Devices Help

icdfa@icdfa: ~
File Actions Edit View Help

Installing:
  sqlmap

Summary:
  Upgrading: 0, Installing: 1, Removing: 0, Not Upgrading: 2562
  Download size: 6,908 kB
  Space needed: 10.9 MB / 4,056 MB available

Get:1 http://kali.download/kali kali-rolling/main amd64 sqlmap all 1.10.6-1 [6,908 kB]
Fetched 6,908 kB in 47s (146 kB/s)
Selecting previously unselected package sqlmap.
(Reading database ... 419622 files and directories currently installed.)
Preparing to unpack .../sqlmap_1.10.6-1_all.deb ...
Unpacking sqlmap (1.10.6-1) ...
Setting up sqlmap (1.10.6-1) ...
Processing triggers for kali-menu (2025.1.1) ...
Processing triggers for man-db (2.13.0-1) ...

(icdfa@icdfa)-[~]
$ sqlmap -u 10.0.2.3/24

{1.10.6#stable}
https://sqlmap.org

[!] legal disclaimer: Usage of sqlmap for attacking targets without prior mutual consent is illegal. It is
the end user's responsibility to obey all applicable local, state and federal laws. Developers assume no
liability and are not responsible for any misuse or damage caused by this program

[*] starting @ 20:20:04 /2026-09-06/

[20:20:04] [WARNING] you've provided target URL without any GET parameters (e.g. 'http://www.site.com/arti
cle.php?id=1') and without providing any POST parameters through option '--data'
do you want to try URI injections in the target URL itself? [Y/n/q] y
[20:20:25] [INFO] testing connection to the target URL
[20:20:25] [CRITICAL] page not found (404)
it is not recommended to continue in this kind of cases. Do you want to quit and make sure that everything
is set up properly? [Y/n] y
[20:20:54] [WARNING] HTTP error codes detected during run:
404 (Not Found) - 1 times

[*] ending @ 20:20:54 /2026-09-06/

(icdfa@icdfa)-[~]
$
```

Part 14

1. Difference between GET and POST: GET requests data via URL query parameters, whereas POST transmits data within the HTTP request body.
2. Parameter: A key-value pair passed from the client to the server to provide variable input for application logic.
3. Cookie Redaction in Reports: Cookies often contain active session identifiers; exposing them risks session hijacking.
4. multipart/form-data: An encoding type used in HTTP POST requests to transmit binary files and form fields in distinct message parts bounded by delimiters.
5. Extension vs. MIME Type: A file extension is a suffix in the filename indicating intended format; a MIME type is an HTTP header (Content-Type) specifying the media format of the payload.
6. Risk of Trusting Client Content-Type: The Content-Type header is entirely user-controlled and easily forged in an intercepting proxy.
7. Storage Outside Web Root: Storing files in an unexecutable directory outside the web root prevents uploaded files from being directly invoked or executed by the server runtime.
8. Nikto Reporting: Web server misconfigurations, missing security headers, default files, and outdated software versions.
9. DIRB Status Codes: 200: Resource exists and is accessible.
301/302: Redirection to another URI.
403: Resource exists but access is forbidden. 404: Resource not found.
10. Baseline Importance: Establishes normal application behavior and response structure to reliably identify anomalies during testing.
11. Single Quote Impact: Breaks the SQL string literal syntax, often triggering an unhandled database syntax error in unparameterized queries.
12. True vs. False Differences: A TRUE condition renders the requested record or all records, while a FALSE condition yields empty results or errors.
13. SQLMap Automation: It automates payload generation, error analysis, boolean/time-based inference, and DBMS fingerprinting.

14. Prepared Statements Function: They compile the SQL query structure beforehand, treating subsequent user inputs strictly as literal parameters rather than executable SQL syntax.

15. Mandatory Authorization: Testing systems without explicit, written authorization is illegal and violates security compliance frameworks.